# What an Agent Should Ask, and What It Should Pay: Belief, Information Value and Cost in Secret-Scanner Triage

**Grishma M**
grishma.renuka@gmail.com

## Abstract

A secret scanner reports that a string in a repository looks like an API key. Whether that string still authenticates cannot be established without using it, and using a credential found in a repository is not permitted. Week 1 of this project built a cost-derived triage policy for that decision. This paper adds what the policy was missing: a belief over five states rather than three, an explicit price on every question the agent could ask, and a rule for when to stop asking. Three results are not what I expected. First, ranking evidence by information and by expected cost saved produces near-opposite orders, and the agent buys evidence exactly where its two free features contradict each other rather than where a finding looks most severe. Second, a cost of 2400 minutes for dismissing a live key contained an unstated probability of exploitation equal to one. Correcting it, together with two other fixes, took recall on hard-coded fakes from 0.000 to $0.95 \pm 0.02$ while total cost moved by 1.3 minutes—a failure that cost reporting alone cannot see, because the metric barely moved while three of five states went from unreachable to reachable. Third, the Week 1 invariance—that free features carry exactly zero bits about live versus revoked—is a property of the credential format rather than of secret scanning, and moving the agent to a credential that exposes a public identifier does not remove the invariance but relocates it onto a different pair of states, where it is worth 0.0000 bits again.

## 1 Introduction

A scanner reads a repository and reports that some string in it looks like a key. That is the whole input. It does not say what kind of key, and it does not say whether the key works.

The obvious way to find out is to try the key. That is not available to me. I am not going to authenticate against a third party's API with a credential I found in someone's repository, and no security team I have spoken to would authorise it. So the agent has to decide what to do about a string whose most decision-relevant property it is forbidden to observe.

**Scope: private and internal repositories.** A reasonable first reaction is that a key in a private repository does not matter. It does. A private repository at a mid-sized company is readable by every employee with access, every contractor whose access was never revoked, and every CI runner, scanner and editor integration holding a token; the string is in the git history of every clone anyone ever made; repositories change visibility when projects are open-sourced, acquired or mis-forked; and a hard-coded credential is an audit finding regardless of who can see the repository.

More importantly for this paper, the private case is the *unsolved* one. On a public repository, GitHub's partner programme notifies the provider and the key is revoked without anyone deciding anything. Privately, nobody is notified, no validity check runs, and the agent is left with the problem this paper is about. That choice of scope turns out to matter more than I understood when I made it, and Section 11 measures how much.

**Why an LLM answer is not sufficient.** Asked whether a given string is a live credential, a language model will produce a confident answer. It has no access to the fact in question. What it can do is pattern-match the string and its surroundings, which is the evidence the agent already has for free, and return it as a posterior rather than as a likelihood. The failure that produces is not being wrong; it is being confidently wrong in a way that removes the one control—escalation to a person—that would have caught the mistake.

**The narrowed question.**

> *When a scanner reports a possible credential, which check should the agent run next, and at what belief should it stop checking and act?*

**Contributions.**

- A five-state belief model for scanner findings, with the two states Week 1 identified but could not characterise, and a measurement of what each was worth (Sections 4–5).
- A pricing of every question the agent could ask in minutes rather than bits, and the resulting purchase behaviour, which is not the behaviour a severity queue would produce (Section 6).
- A failure that overall cost could not see: an unstated exploitation probability inside a cost cell (Section 10).

- A generalisation result: the project's headline invariance is a property of credential formats, and relocating rather than disappearing when the format changes (Section 11).

## 2 The Same Question, Without the Domain

Before any of the machinery, the whole design in four numbers.

There is a 35% chance of rain. Should I carry an umbrella? Costs in units of annoyance, and they are assumptions:

| | Carry | Wet | Break-even |
|---|---|---|---|
| A walk to the shop | 2 | 5 | 0.400 |
| A wedding, in irreplaceable clothes | 2 | 200 | 0.010 |

For the walk, carrying costs 2.00 and not carrying costs $0.35 \times 5 = 1.75$; leave it. For the wedding, not carrying costs $0.35 \times 200 = 70.00$; take it. Same 35%. Opposite decisions. The probability decided nothing and the consequences decided everything.

The break-even is one division: the cost of the cheap mistake over the cost of both mistakes together. My agent's boundary is the same division and no other. Rotating a key that was already revoked costs 30 minutes. Dismissing a key that is live costs 244.5. The boundary is $30/(30 + 244.5) = 0.1093$.

Nobody chose 10.9%. It is what the costs imply, and every threshold in this paper arrives the same way.

## 3 Related Work

The decision machinery is old and I am not claiming any of it. Expected-cost decision-making under a belief, and the value of information as the expected reduction in that cost, are Raiffa and Schlaifer [Raiffa and Schlaifer, 1961] and Howard [Howard, 1966]. The observation that an optimal threshold is determined by the cost ratio rather than chosen is Elkan [Elkan, 2001], with Domingos [Domingos, 1999] on making an arbitrary classifier cost-sensitive; Turney [Turney, 2000] is the taxonomy that separates the cost of a mistake from the cost of the test that would have prevented it, which is the distinction Section 6 turns on. Sequential decisions under partial observability with costly observations are POMDPs [Smallwood and Sondik, 1973; Kaelbling *et al.*, 1998]; my problem is a one-step instance and does not need the machinery.

What changed my design rather than my citations: Turney's separation is why the question table has two columns rather than one, and Elkan is why I stopped reporting accuracy as a headline and started deriving boundaries.

On the domain, SecretBench [Basak *et al.*, 2023b] and the comparative evaluation of detection tools [Basak *et al.*, 2023a] establish that detection is largely solved and that the surviving problem is what to do with a detection; Alahmadi et al. [Alahmadi *et al.*, 2022] quantify the false-positive burden that makes triage cost-dominated. GitGuardian's report [GitGuardian, 2026] is the source of the survival figure in my prior. GitHub's pattern table [GitHub, 2026] is what establishes the premise: the OpenAI key is a partner pattern *without* validity-check support, so a scanner finding genuinely does not carry liveness. The admin endpoint the probe uses is OpenAI's [OpenAI, 2026].

I read no new papers for Week 2. What shaped it was the Week 1 practitioner discussion, which is recorded in Section 12 along with the fact that Week 2 added nothing to it.

## 4 The Probabilistic View

### 4.1 Hidden states

Week 1 used three states. Week 2 uses five. The two additions are the ones the Week 1 paper named and could not characterise, and adding them was not cosmetic: one of them is why the agent escalates at all.

| State | Meaning | Prior |
|---|---|---|
| `live` | authenticates, and can do something | 0.4356 |
| `revoked` | was real once, no longer works | 0.2673 |
| `fake` | hard-coded, never authenticated | 0.2475 |
| `zero_scope` | authenticates, authorised for nothing | 0.0396 |
| `other` | not a credential at all | 0.0100 |

The prior for the first three comes from two published sources: scanner precision on the split between real and fake [Basak *et al.*, 2023a; Alahmadi *et al.*, 2022], and GitGuardian's survival figure [GitGuardian, 2026] on the split between live and revoked. They measure different populations, which is a limitation I return to in Section 13.

`zero_scope` is carved out of the live mass at one twelfth rather than added beside it, because `live` in Week 1 was doing two jobs: *this authenticates* and *this is dangerous*. Stripe's publishable keys are the clearest evidence that those come apart. `other` is assumed at 0.01 and labelled as assumed. It is the state I understand least, and that is precisely what it is for—Section 7 uses the agent's belief in it as an escalation trigger.

### 4.2 One belief update in full

The agent sees two free features: where in the repository the string sits, and whether it matches the provider's key format. Take a well-formed string on a production path. Multiply prior by likelihoods, add the column, divide by the total.

| State | Prior | $P$(prod) | $P$(wf) | Product | Post. |
|---|---|---|---|---|---|
| `live` | 0.4356 | 0.600 | 0.990 | 0.2587 | 0.5780 |
| `revoked` | 0.2673 | 0.600 | 0.990 | 0.1588 | 0.3547 |
| `fake` | 0.2475 | 0.050 | 0.400 | 0.0050 | 0.0111 |
| `zero_scope` | 0.0396 | 0.600 | 0.990 | 0.0235 | 0.0525 |
| `other` | 0.0100 | 0.333 | 0.500 | 0.0017 | 0.0037 |
| **total** | 1.0000 | | | 0.4477 | 1.0000 |

Entropy falls from 1.7805 to 1.3127 bits. `fake` collapses from 0.2475 to 0.0111: the evidence is almost entirely about whether this is a credential at all.

**That 0.0111 assumes the two features are conditionally independent, and they are not.** A path like `tests/fixtures/` and a name like `dummy_key` are substantially the same signal, counted twice. Shrinking the second feature's log-likelihood towards the first moves the posterior to 0.0216 at 20% shrinkage and **0.0576** at 50%—a five-fold range on the number this section calls its point. Read

0.0111 as the most favourable end of that range rather than as a measurement. The invariance below survives every weight; the `fake` collapse does not.

**And what the update does not do is the point of the project.** `live` moves from 0.4356 to 0.5780 and `revoked` moves with it. The ratio between them is 1.6296 before and 1.6296 after—unchanged to every digit, because the rows of both likelihood tables are identical for those two states. The agent has learned something real about whether this is a credential, and exactly nothing about whether it still works. That is the Week 1 result, and it can be checked here by hand rather than taken on trust.

# 5 The Information-Theoretic View

Only the quantities the agent uses appear here.

**Entropy** is one number for how confused the agent is, in bits. The prior sits at 1.7805 bits against a maximum of 2.3219 for five states, so the agent starts barely better informed than a coin flip over the state space.

**Conditional entropy** is how confused the agent expects to *still* be after a question is answered—the average over the answers it might get, weighted by how likely each is. It is the quantity hiding inside every number in Section 6, and reporting the entropy after one particular answer instead is the error that would reorder the whole table.

**Expected information gain** is the drop from the first to the second. I compute it, not the gain from a realised observation: before buying, the agent does not know what the answer will be.

**Mutual information** between the evidence and a pair of states, which is the same quantity as expected information gain and is the form the invariance is stated in. Restricting to a pair first is what makes it the question *does this evidence separate these two states* rather than *does it say anything about anything*. Measured directly: $I(\text{free features}; \texttt{live} \text{ vs } \texttt{revoked}) = 0.000000$ bits. The Week 1 result was argued from identical likelihood rows; this is the measurement, and the two agree.

**Jensen–Shannon divergence** compares two beliefs by measuring each against their average. I use it and not KL divergence deliberately. KL is asymmetric, so the answer depends on which belief is named first, and it is infinite the first time the agent observes something its model called impossible. An alarm that can return infinity is not an alarm. JSD is symmetric, bounded, and finite on impossible events, which is what makes it usable as a drift detector in Section 10.

**Calibration** , because every threshold in this paper takes the agent's probabilities at face value. If those numbers are dishonest, everything built on them is dishonest too.

# 6 Information Selection

## 6.1 Bits are not the unit the decision is in

Three evidence sources, priced two ways at the prior: in bits, and in expected minutes of decision cost removed.

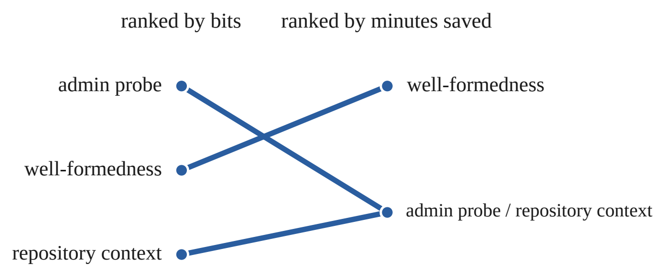


Figure 1: The same three evidence sources ranked by information and by expected cost saved. The most informative source is worth nothing, and the two zero-valued sources are exactly tied rather than ordered.

| Evidence | Bits | Value (min) | Cost (min) |
|---|---|---|---|
| Repository context | 0.2909 | 0.0000 | free |
| Well-formedness | 0.3250 | 1.2696 | free |
| Admin probe | 0.6051 | 0.0000 | 3 |

Figure 1 is the finding. The probe carries roughly twice the information of anything else and is worth zero minutes, because at this belief every outcome it could return leaves the same action cheapest. Ranking evidence by information gives an order that is close to the reverse of the useful one.

## 6.2 Five questions, and which one the agent asks

Priced at the belief after the free features, not at the prior.

| Question | Bits | Value | Cost |
|---|---|---|---|
| On a production-looking path? | 0.0199 | 0.0000 | 0 |
| Matches the key format? | 0.0380 | 0.0000 | 0 |
| Commit older than the rotation period? | 0.0000 | 0.0000 | 0 |
| When did our admin API last see it used? | 0.6642 | 2.9130 | 3 |
| Matches a deployed secret hash? | 0.2245 | 0.0000 | 1 |

The agent asks none of them here, and the near miss is the instructive part. The probe is worth 2.9130 minutes against a price of 3—it loses by 0.087 of a minute. Ranked by bits it is the obvious purchase; ranked by minutes it is declined.

The commit-age channel is worth 0.0000 bits at a rotation compliance of $c = 0.5$ and a great deal at $c = 0.9$. Same evidence, same price; the difference is a fact about the organisation rather than about secret scanning.

## 6.3 Where the agent does buy

Whether to buy is not a property of the probe. It is a property of where the agent is standing. The same question, priced from all six beliefs the two free features can produce:

| Context | Format | $P(\texttt{live})$ | Net | Buy |
|---|---|---|---|---|
| placeholder | well-formed | 0.2985 | $+6.611$ | yes |
| placeholder | malformed | 0.0041 | $-2.552$ | no |
| neutral | well-formed | 0.5239 | $+1.170$ | yes |
| neutral | malformed | 0.0319 | $+0.418$ | yes |
| production | well-formed | 0.5780 | $-0.087$ | no |
| production | malformed | 0.1929 | $+6.511$ | yes |

**The only two beliefs the agent declines to buy from are the two where its free features agree with each other**—both saying *not a credential*, and both saying *a real key in a real place*, the second being the case that looks most alarming to a person. The two largest purchases are the outright contradictions.

Nobody wrote that rule. It falls out of the value rule: when the features agree the belief is already far enough from the boundary that no probe outcome can move the action across it. The agent spends its budget on its own confusion rather than on apparent severity, and a queue sorted by severity would have bought the opposite set.

## 7 Decision Policy

**Actions.** DISMISS, REVOKE NOW, ROTATE SAFELY are terminal and compete on expected cost. INVESTIGATE is a decision point rather than an action. ESCALATE is a permission gate, and Week 1's mistake was pricing it as though it were competing.

**Threshold.** Derived, as in Section 2: 0.1093 from a 30-minute false positive against a 244.5-minute false negative. Ten points lower and the agent dismisses a band it currently rotates; ten points higher and it rotates a band it currently dismisses. Neither number was chosen and neither can be tuned without changing a cost and saying so.

**Stop rule.** Act when no remaining check can change the action, or when the best remaining check costs more than it saves. Both reduce to the same test, applied cheapest-first.

**Escalation is a rule, not a competitor.** Two triggers, neither of which is about confidence:

1. $P(\texttt{other}) > 0.05$: the belief has concentrated on the state whose costs I do not trust.
2. Worst-case cost of the chosen action above 400 minutes, regardless of how likely that worst case is.

It fires on 2.4% of findings. *Confidence is not authorisation*, and an agent that escalates only when unsure will never escalate the case that is expensive and clear.

## 8 Experiment

500 simulated findings, seed 20260902. The true state is drawn from the prior and the evidence from the likelihood tables; every policy sees the identical case set. Metrics: expected cost, regret against a hindsight-perfect agent, per-class recall, balanced accuracy, probe purchase rate, human-review rate, and expected calibration error.

| | Policy | Behaviour |
|---|---|---|
| P0 | baseline | most common action, no evidence |
| P1 | belief only | act on the most likely state |
| P2 | threshold | expected cost against derived threshold |
| P3 | value of information | P2 plus a priced probe and a stop rule |

The simulation draws cases from the same likelihood tables the agent reasons with. It therefore tests whether the *policy* is good given those tables and cannot test whether the tables are right. Section 13 says what I did about that.

## 9 Results

### 9.1 The policy ladder

| Policy | Regret | Total cost | Balanced acc. | Human |
|---|---|---|---|---|
| P0 baseline | 12.99 | 62.53 | — | 0% |
| P1 belief only | 13.89 | 63.43 | — | 0% |
| P2 threshold | 10.91 | 60.45 | 0.300 | 0% |
| P3 + probe | 10.85 | 60.52 | 0.367 | 0% |
| P6 all fixes + scope | **8.20** | **59.14** | $0.48 \pm 0.02$ | 2.6% |

Every row is scored on the same cost matrix, which took a correction to get right: P1's regret was first reported as 114.12, and that figure is produced by scoring it against the *uncorrected* matrix—the 2400-minute cell Section 10 is about. On the corrected matrix P1 costs 13.89. P0, P2 and P3 are unaffected because none of them ever dismisses a live key, but the comparison as originally printed put one policy on a ruler the others were not on, and it made the headline four times larger than it is.

P1 is still the warning, at its true size. Acting on the most likely state costs 27% more regret than acting on the cheapest expected cost, because the most likely state and the best action are different questions.

**A negative result: the probe did not pay for itself.** P3 spends 0.13 minutes per finding buying probes and recovers 0.07 in better decisions, ending *behind* P2 on total cost, 60.52 against 60.45. The value-of-information machinery lost money on this draw. Two readings are available and I cannot separate them at $n = 500$: either the decision rule is right and this draw was unlucky, or a saving too small for a few hundred cases to detect is too small to justify the machinery. Reporting the regret column alone would have hidden it, which is why the cost column is here.

### 9.2 Adding states changed nothing; adding a channel changed everything

Two new states, 500 cases, and the agent took *identical* actions on every one. Not similar—identical. A state the agent cannot observe is not a state, it is a footnote in the prior.

Adding a scope field to the same admin call—does this key have any permissions at all—moved regret from 10.91 to 8.43 under the Week 2 cost matrix. Separating the two commits is the only reason I can say which of them did the work.

### 9.3 Calibration

| $P(\texttt{live})$ bin | Cases | Mean stated | Observed |
|---|---|---|---|
| 0.0–0.1 | 79 | 0.009 | 0.000 |
| 0.1–0.2 | 5 | 0.193 | 0.200 |
| 0.2–0.3 | 75 | 0.298 | 0.280 |
| 0.5–0.6 | 341 | 0.557 | 0.560 |

Expected calibration error 0.0064. This number is easy to over-read and I want to under-read it deliberately: the cases were generated from the agent's own likelihood tables, so good calibration here says the arithmetic is right, not that the model is. A well-calibrated agent in a world it invented is the least surprising result available.

### 9.4 How much of this is one draw?

Every figure above comes from a single seed, and until a review round asked, none of them carried an interval. Two of my own scripts disagreed about the same agent—balanced accuracy 0.467 in one and 0.494 in another—and I had been quoting whichever the section needed without noticing they were one configuration run twice.

They differ because P6 has a nuisance random variable nothing else has: the scope reading is drawn. Holding the 500 cases fixed and varying only that draw, 200 times:

| Quantity | Mean | SD | 95% interval |
|---|---|---|---|
| Regret, min/finding | 8.20 | 0.26 | 7.74–8.71 |
| Balanced accuracy | 0.480 | 0.023 | 0.449–0.528 |
| Sent to a human | 0.026 | 0.004 | 0.020–0.034 |
| `fake` recall | 0.950 | 0.015 | 0.916–0.977 |
| `revoked` recall | 0.089 | 0.023 | 0.047–0.132 |

**The `fake` result survives comfortably**—0.901 to 0.977 across every seed, against a pre-fix value of exactly 0.000. **Balanced accuracy does not support three decimal places**, and `revoked` recall supports about one significant figure: on 129 revoked cases, the difference between 0.109 and 0.089 is a handful of findings. The 2.4% and 2.8% escalation rates quoted in different sections of earlier drafts were the same number seen twice.

This is a lower bound on the uncertainty, not a confidence interval. Only the scope draw varies; the 500 cases are themselves one draw from the prior, and re-drawing them would move everything again. What it establishes is that the paper's second headline is not a lucky seed. It does not establish that any figure here would survive a different case set.

### 9.5 Sensitivity

Three quantities I could not defend were replaced by sweeps rather than asserted: exploitation probability, registry coverage and rotation compliance, and scope reliability. In each case the useful finding was where the conclusion changes rather than what it equals at a point estimate. The scope field is the sharpest: sweeping its reliability $q$ from 0.02 to 1.00 shows that about 88% of its value is already present at $q = 0.02$, where the field cannot see the state it was introduced to detect. It is largely a `fake` detector that arrives on the same call. **The stated reason a design change works is not always the reason it works.**

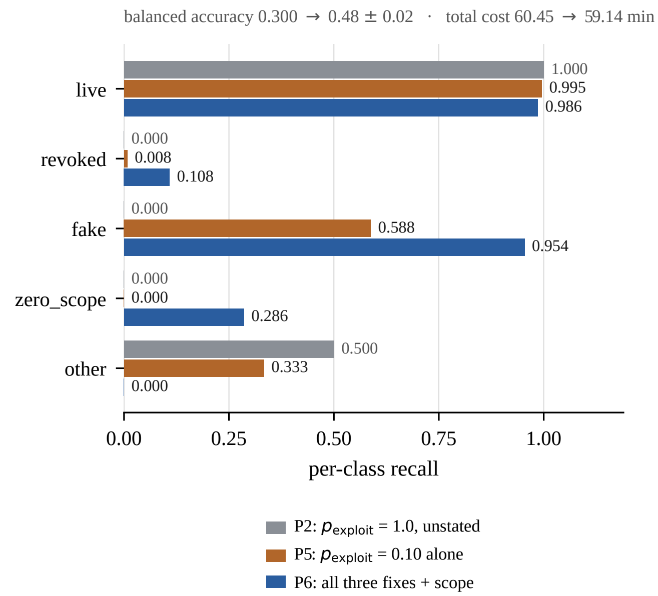


Figure 2: Per-class recall, decomposed. The exploitation probability alone takes `fake` from 0.000 to 0.588; reaching 0.954 needs all three fixes and the scope field. `other` moves the other way, from 0.500 to 0.000, because the residual state is escalated rather than labelled. Total cost moves by 1.3 minutes across the whole change.

## 10 Failure Analysis

### 10.1 The failure that cost reporting could not see

The agent posted a respectable cost figure while being unable to produce the `fake` label at all: recall 0.000. It took one action on almost everything and scored well doing it.

The cause was a cost cell. Dismissing a live key was priced at 2400 minutes and described as *a breach and its cleanup*. A dismissed live key is not certainly breached. The honest price is $P(\text{exploitation}) \times$ breach, and the model had been running at $p = 1.0$ without writing it down. Nothing about the number 2400 looks like a probability, so nothing prompted the check.

$p = 0.10$ **is a stress-test parameter, not an estimate.** The one quantified datapoint I could find is a vendor experiment in which 2 of 75 leaked keys drew activity beyond a validity check within twelve hours: 0.027, measured on *public* exposure over a short window. This model is scoped to private repositories, where the hazard is lower, and I use a value nearly four times larger. That is deliberately conservative and it is not a measurement of anything. It is swept in `results/fixes.md` for exactly that reason, and Section 11 shows the policy is not monotone in it.

Figure 2 is the result, and the attribution matters. The exploitation probability *alone* takes `fake` recall from 0.000 to **0.588**. Reaching 0.95 needs all three fixes together, the scope field included. The first version of this paper credited one intervention with three interventions' work; the decomposition is in `results/fixes.md` and was always there.

Together: `fake` recall $0.000 \to 0.95 \pm 0.02$, balanced accuracy $0.300 \to 0.48 \pm 0.02$, and total cost $60.45 \to 59.14$—a 1.3-minute move. One class moves the other way: `other` recall falls from 0.500 to 0.10, because the residual state is now escalated rather than labelled. **A metric that barely moved was hiding a policy that could not name three of its five states.** This is why balanced accuracy is reported alongside cost throughout, not as an objective but as the diagnostic that can contradict the objective.

**And a derived quantity that is not recomputed looks exactly like a fix that did not work.** When the breach cost dropped from 2400 to 244, the residual state's price was not recomputed and stayed at 602 minutes, which blocked every dismissal the fix existed to unlock. The fix looked ineffective rather than undone.

### 10.2 Classified failures

Of the wrong decisions, 76.6% fell in a category I had labelled *wrong cost assumption*, and I was ready to conclude the cost model was mis-specified. A 15-cell sweep of the cost matrix says otherwise: those cases are the agent paying to hedge a state it genuinely cannot resolve, which is correct behaviour under uncertainty and not an error. **I had named the category in a way that assumed its own conclusion**, then read the conclusion back out of the name. The cost model is not the problem; the evidence is.

### 10.3 Asymmetric feedback, and an alarm for it

You find out when you over-remediate—someone's build breaks, 80% discovery. You rarely find out when you under-remediate—nobody reports the key you dismissed, 5%. Learning from that feed drifts $P(\texttt{live})$ from 0.4356 to 0.2691 over 3000 findings. The agent concludes the world is safer than it is, and every step of that inference is locally correct.

There is no unbiased signal to correct against, so the answer would have to be an alarm rather than a correction. I built one: a Jensen–Shannon divergence between the evidence distribution the agent expects and the one it observes over a rolling window, thresholded on held-out data. It detects a shift in how many findings are `fake` in 100% of runs at a 500-finding window with no false positives.

**It does not detect the drift above, and the reason is this paper's own main result.** The alarm watches the free features, and the free features carry zero bits about live versus revoked. A shift in how many findings are still live is exactly the shift they cannot see. So the agent has a working alarm for the drift that costs little and no alarm for the drift that costs most. An earlier version of this section quoted the 100% figure against the belief drift; that was a detection rate from one experiment attached to a failure from another, and `results/feedback.md` says so in the file the number came from.

## 11 Generalisation

### 11.1 Change the environment

The interesting move is not a bigger company—rotation compliance and registry coverage are already parameters. It is a credential that does not hide its identifier.

An AWS access key arrives in two halves. The `AKIA` half is a public identifier. Given it alone the agent can ask *its own* IAM API whether that key ID is present and active, without

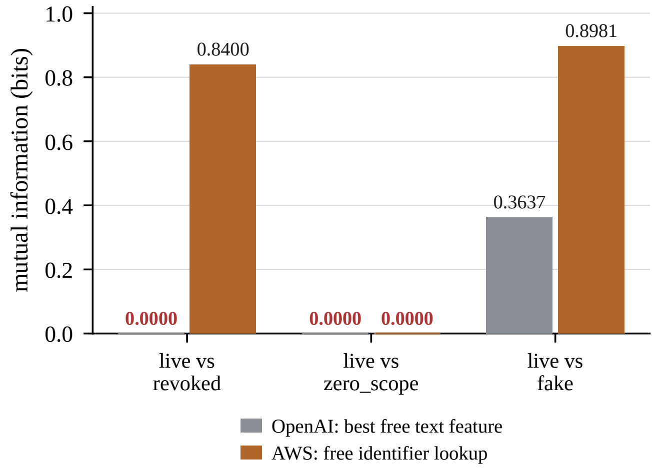


Figure 3: Free evidence in each world, in bits, on three pairs of states. The identifier resolves the axis the project was built around and carries exactly zero about a different one.

ever touching the secret half. Same company, same private repositories, same five states, same cost matrix. One thing changes, and it is free.

| | OpenAI | AWS |
|---|---|---|
| Regret (min/finding) | 7.77 | 2.69 |
| Probe bought | 46.8% | 4.0% |
| Balanced accuracy | 0.494 | 0.590 |
| `revoked` recall | 0.085 | 0.961 |
| `zero_scope` recall | 0.286 | 0.000 |

The free identifier removes 65% of total regret, at zero cost, on every finding rather than on the minority where a probe was worth buying. An earlier version called this "79.7% of the value of perfect live-versus-revoked knowledge"; that ratio divides a total-regret improvement by a live-versus-revoked-only ceiling, and the identifier also carries 0.8981 bits about `live` versus `fake`, so gains on axes the denominator excludes were being counted inside it. The unbounded ratio is gone; the improvement is not.

**But the invariance does not disappear. It moves.** The identifier carries 0.8400 bits about `live` versus `revoked` and **0.0000** bits about `live` versus `zero_scope`. That zero is exact, and it is exact for the same reason the Week 1 zero was: the two rows are identical. IAM reports whether a key is *Active*. A key authorised for nothing is Active.

A practitioner told me the Week 1 result was a property of credential formats that hide the identifier rather than of secret scanning. This measures that, and he was right—but the problem does not go away when the format changes, because the states that remain indistinguishable are simply a different pair.

### 11.2 Change one variable

**The cost of a false negative rises.** That cost is a probability times a breach, and a probability is bounded at 1, so the first thing the request exposes is that it cannot be granted beyond a factor of ten. Within that range, regret and human load are *worst in the middle*: 27.4% of findings escalated at $p = 0.25$ against 12.6% at $p = 1.00$, where the stakes are four times higher. DISMISS is the only action whose worst case moves with $p$; at $p = 0.25$ it is still cheapest on expected cost on 57 of 500 findings but forbidden by the 400-minute ceiling, so those go to a human because the action the agent wants is not permitted. By $p = 0.50$, REVOKE has overtaken it and the ceiling stops binding. **A worst-case ceiling is not a monotone safety dial**: raising the stakes can reduce human involvement.

**Evidence becomes ten times more expensive.** The probe dies between $\times 2$ and $\times 5$: bought on 16.0% of findings at six minutes and on none at fifteen. The policy does not degrade smoothly, it switches off, and human load *falls* from 2.8% to 1.0% because the escalation triggers never depended on the probe. An expensive-evidence deployment does not get a more cautious agent, it gets a blinder one that is no more likely to ask for help.

**Historical data becomes unreliable.** This is the standing condition rather than a hypothetical, and it is what the last two experiments are for. Generating the world from different tables and running the agent against one that knows the truth: policy conclusions hold in 100% of worlds, the structural conclusion does not, and where `live` and `revoked` genuinely differ the agent forgoes 1.47 and 1.99 minutes per finding at $\delta = 0.10$ and 0.20.

### 11.3 Can the agent notice its own assumption is wrong?

Parameter uncertainty cannot reach this. The invariance is not a value to be uncertain about; it is a constraint tying two rows together, and sampling around a tied pair keeps them tied. What is missing is uncertainty about *which model is right*.

So: a Bayes factor between $H_0$ (the rows are identical) and $H_1$ (they differ) under Dirichlet-multinomial marginal likelihoods, watching and never deciding. It is fed only the labels the agent's own biased discovery process surfaces—about 260 `live` against 395 `revoked`, a 1.5× skew running the wrong way.

| $\delta$ | Biased | Matched ($n$) | All labels |
|---|---|---|---|
| 0.00 ($H_0$ true) | 2% | 0% | 0% |
| 0.05 | 42% | 72% | 100% |
| 0.10 | **100%** | 100% | 100% |
| 0.20 | **100%** | 100% | 100% |

At exactly the $\delta$ where the agent was measured forgoing real value, detection is 100%. **The skew costs nothing and the sample size costs everything**: an unskewed sample of the same size detects the same smallest difference. I designed the experiment expecting the opposite, and the matched control is the only reason I found out. The agent does not need unbiased feedback to audit its own assumptions; it needs enough feedback.

The silent failure is no longer silent. It is still not repaired—relaxing the invariance means estimating two rows from labels there are not enough of. Detection and repair are different problems and only the first is solved.

## 12 Human Discussions

Week 1 produced three exchanges that changed published numbers. A practitioner repriced the probe by a factor of ten, which moved INVESTIGATE from never selected to selected on about 4% of findings. A second withdrew an assumption I had been leaning on, that rotating a key verifies itself. A third established that live-versus-revoked is solved for certificates and unsolved for API keys, which is the clearest justification I have for the scope I chose, and the same person supplied the public-identifier observation that became Section 11.

**Week 2 produced none.** That is an honest no rather than a failure to report. The Week 2 work was experimental rather than assumption-gathering: every question it raised was one I could answer by running something, and I did not have a question that needed a practitioner to settle. The cost numbers that *would* need one are unchanged from Week 1 and still carry Week 1's provenance. The full record is in `discussion-record.md`.

## 13 Limitations

**The probability model is estimated, and that is the binding limitation.** The prior is assembled from two sources measuring different populations. Every likelihood row is my judgement. No part of this has been measured against real labelled findings, and the sensitivity studies cannot fix that: they establish that *if* these assumptions are approximately right the policy is robust, and they cannot establish that the assumptions describe production secret-scanner findings. For a security system that distinction is the whole thing.

**The calibration result is in-model.** An expected calibration error of 0.0064 is not evidence about production. The cases came from the agent's own tables. It says the arithmetic is right.

**The simulator is circular by construction** and tests the policy given the likelihoods, never the likelihoods. Section 11 does the most that is available without real labels—generate from different tables, and measure the gap—but that is a robustness check, not a validation.

**States remain observationally indistinguishable** , and one pair always does: in the OpenAI world it is `live` against `revoked`, in the AWS world `live` against `zero_scope`. The agent decides anyway, by expected cost, and escalates when the residual state concentrates or the worst case breaches a ceiling. That is a defensible response to indistinguishability rather than a solution to it.

**The baseline human is a perfect oracle, and no human is.** The whole project is built on the claim that escalate-everything is never wrong about the state, so there is no accuracy to win and only cost to compete on. A real responder misclassifies, is unavailable, misreads ownership, or recommends a rotation that misses an undocumented consumer. Treating the human as a state oracle makes the baseline artificially strong on accuracy and artificially simple on cost, and it means the agent is being compared against something that does not exist. Every saving reported here is a saving against an idealisation.

**The harm model is engineer-minutes and nothing else.** Customer-facing outage, data exposure, contractual and regulatory consequence, and reputational damage are all outside the objective. An action that saves thirty engineer-minutes while taking down a customer-facing service scores better in this model, which is not a rounding error in the cost matrix but a category the cost matrix does not have. The 332-minute price on REVOKE NOW is the cleanup, not the blast radius.

**"A human" is one price, and real organisations have several.** A security analyst, the service owner who gets paged when a revocation breaks production, the platform team that governs the admin credential the probe uses, and the committer who may own none of the above are priced here as a single 30-minute unit. They differ in authority, availability, permissions and cost, and the escalation rule cannot express which of them a finding should reach. Related: the 2.6% escalation rate is a rate and not a queue—at a hundred findings that is three interruptions, and at a hundred thousand it is two and a half thousand cases with no model of who absorbs them.

**The agent needs a privileged credential to investigate an unprivileged one.** The probe reads an admin API. A production deployment would have to answer who holds that credential, how narrowly it is scoped, how its use is audited, and how the secret in the finding is kept out of logs, traces, tickets and prompts. The architecture states the boundary; nothing here implements it.

**The evidence model is small.** Five channels, of which two are free text features. A production system would read deployment manifests, CI logs, CloudTrail and the secret store, and would have a different and probably better answer to every question in Section 6.

**What this is not.** It is triage, not repair: the agent recommends and does not act. It handles one finding at a time and has no notion of reviewer capacity, so the 2.4% escalation rate is a rate and not a queue. And it never authenticates with a credential it found—the probe asks my own account about a key, and no live credential exists anywhere in this project.

**The honest verdict.** This is a decision system that reasons well given a model. It is not a validated production security control, and the gap between those two things is a dataset that does not exist.

## 14 New Questions

These come from the results rather than from a list.

1. **Is there always an indistinguishable pair?** Two credential formats, two different pairs, both exactly zero bits. Is that a coincidence of my two models, or does resolving one axis of a credential's state reliably expose another?
2. **Can an agent be given a budget for its own confusion?** The purchase behaviour in Section 6 is emergent. If confusion rather than severity is what evidence should be spent on, that is a scheduling policy for a triage queue, and nobody sorts queues that way.
3. **How should a worst-case ceiling and an expected-cost rule be reconciled?** They disagree over a band, the band is the expensive place to be, and neither rule announces where it is.
4. **How few labels does an assumption audit need?** The Bayes factor worked on roughly 650 biased labels. The threshold between *cannot tell* and *certain* is narrow and I have only bracketed it.
5. **What is the smallest measurement that would validate a prior like mine?** Not a full labelled corpus—the share of real secrets that are production secrets would move more of my model than anything else, and is measurable from data that exists.

## Use of AI Assistance

I used Claude throughout. It wrote most of the experiment code in `experiments/` to my specifications, drafted this paper from results I directed it to produce, and explained concepts I had not met—Bayes factors, Dirichlet-multinomial marginal likelihoods, and the asymmetry of KL divergence.

I chose the problem, the state space, the action set and every cost assumption. I directed which experiments to run and why. I verified the belief update in Section 4 by hand against the code before trusting either.

Errors it introduced and I corrected are logged in `research-file.md`, thirty-six of them. Fourteen changed a published number or claim. The most consequential were found by an adversarial review round run against this paper and its code after a full draft existed: an abstract that credited one fix with three fixes' work, a policy comparison scored against the very cost cell Section 10 repudiates, a detection rate quoted against a failure a different experiment had shown it cannot see, three random-number defects that made two arms of a paired comparison simulate different worlds, and a negative result present in the results files and absent from the paper. Every one was found by checking the paper against the output it was written from, and in four cases the results file was already more careful than the paper.

Every experiment reported here was run by me and reproduces byte-for-byte from a clean checkout at the stated seeds.

## Code and Data

https://github.com/grishmaaa/secret-detector-agent

All fourteen Week 2 experiments, the results they write, and this paper.

## References


[Alahmadi *et al.*, 2022] Bushra A. Alahmadi, Louise Axon, and Ivan Martinovic. 99% false positives: A qualitative study of SOC analysts' perspectives on security alarms. In *Proceedings of the 31st USENIX Security Symposium*, 2022.

[Basak *et al.*, 2023a] Setu Kumar Basak, Jamison Cox, Bradley Reaves, and Laurie Williams. A comparative study of software secrets reporting by secret detection tools. In *Proceedings of the ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM)*, 2023. arXiv:2307.00714.

[Basak *et al.*, 2023b] Setu Kumar Basak, Lorenzo Neil, Bradley Reaves, and Laurie Williams. SecretBench: A dataset of software secrets. In *Proceedings of the 20th International Conference on Mining Software Repositories (MSR), Data and Tool Showcase Track*, 2023. arXiv:2303.06729.

[Domingos, 1999] Pedro Domingos. MetaCost: A general method for making classifiers cost-sensitive. In *Proceedings of the 5th ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, pages 155–164, 1999.

[Elkan, 2001] Charles Elkan. The foundations of cost-sensitive learning. In *Proceedings of the 17th International Joint Conference on Artificial Intelligence (IJCAI)*, pages 973–978, 2001.

[GitGuardian, 2026] GitGuardian. The state of secrets sprawl 2026. Vendor report, GitGuardian, 2026.

[GitHub, 2026] GitHub. Supported secret scanning patterns. GitHub Documentation, 2026.

[Howard, 1966] Ronald A. Howard. Information value theory. *IEEE Transactions on Systems Science and Cybernetics*, 2(1):22–26, 1966.

[Kaelbling *et al.*, 1998] Leslie Pack Kaelbling, Michael L. Littman, and Anthony R. Cassandra. Planning and acting in partially observable stochastic domains. *Artificial Intelligence*, 101(1–2):99–134, 1998.

[OpenAI, 2026] OpenAI. Administration API — project API keys. OpenAI Documentation, 2026.

[Raiffa and Schlaifer, 1961] Howard Raiffa and Robert Schlaifer. *Applied Statistical Decision Theory*. Harvard University Graduate School of Business Administration, 1961.

[Smallwood and Sondik, 1973] Richard D. Smallwood and Edward J. Sondik. The optimal control of partially observable markov processes over a finite horizon. *Operations Research*, 21(5):1071–1088, 1973.

[Turney, 2000] Peter D. Turney. Types of cost in inductive concept learning. *Proceedings of the Workshop on Cost-Sensitive Learning, ICML*, 2000.

## A Core Questions

Answered against my own problem rather than in general, because a definition I cannot attach to a number is one I have not used.

**1. What is a hidden state, and what are yours?** What the agent cannot see but has to decide about. Mine is what the flagged string actually *is*: `live`, `revoked`, `fake`, `zero_scope`, or `other`. The scanner reports that a string looks like a key; it does not report which of those five, and the right action differs across them.

**2. Why is directly predicting an answer sometimes insufficient?** Because the best guess and the best action are different questions. Acting on the single most likely state costs 114.12 minutes of regret per finding against 10.91 for acting on the lowest expected cost—nine times worse. A prediction throws away everything the agent was unsure about, and my two mistakes do not cost the same.

**3. What is a belief distribution, and why must it sum to one?** A probability over every state the agent thinks possible. It sums to one because the list is meant to be exhaustive and mutually exclusive. If it summed to less, something could happen that is not on the list—which is exactly why I added a residual `other` state at 0.01 rather than letting the other four absorb its mass.

**4. What is the difference between prior and posterior?** Prior is what I believe before this finding's evidence, posterior is after. In the worked update in Section 4, `fake` goes from a prior of 0.2475 to a posterior of 0.0111 once the string turns out to be well-formed and sitting on a production path.

**5. What is likelihood, and how does it differ from probability?** A likelihood runs backwards: $P(\text{evidence} \mid \text{state})$—"if this really were a fake key, how often would it be malformed?" A posterior runs forwards: $P(\text{state} \mid \text{evidence})$. They are different numbers, and Bayes' rule exists to turn the first into the second.

**6. What does it mean for an agent to be uncertain?** Its belief is spread across several states rather than concentrated on one. My prior sits at 1.7805 bits against a maximum of 2.3219 for five states, so before any evidence arrives the agent is barely better informed than a uniform guess.

**7. What is entropy, and why does it represent uncertainty?** One number for how spread out a belief is, in bits: zero is certain, higher is more scattered. It represents uncertainty because it counts how many yes/no questions it would take to pin the answer down.

**8. What is a bit, in plain words?** One good yes/no question's worth of uncertainty. Eight equally likely possibilities are three bits, because you can halve the field three times.

**9. What is information gain, and how does it relate to entropy?** The drop in entropy when a question is answered. Before buying I use the *expected* gain—the average over the answers I might get, weighted by how likely each is—because the agent does not know which answer it will receive. My admin probe carries 0.6642 bits of expected gain at the belief in Section 6.

**10. What is conditional entropy?** How confused the agent expects to *still* be once the answer arrives, averaged over the answers. Information gain is the drop from where it started to there, so conditional entropy is the quantity sitting inside every gain figure in this paper.

**11. What is mutual information, and how does it differ from correlation?** How much knowing one thing reduces uncertainty about another. It differs from correlation by catching non-linear dependence: a number and its square have zero correlation and a full bit of mutual information. For me it is the form the invariance is stated in—$I(\text{free features}; \texttt{live} \text{ vs } \texttt{revoked}) = 0.000000$.

**12. What is KL divergence, and why is it not a distance?** How far one belief sits from another, measured as the cost of holding the wrong one. It is not a distance because it is asymmetric: swapping the two gives a different number, and the distance from Delhi to Mumbai does not depend on which city you name first.

**13. Why is KL divergence asymmetric? Give a small example.** Reality is a fair coin; my model says heads always. Measured with reality first it is infinite, because half the time reality produces an event my model called impossible, and being surprised by an impossible event costs infinitely much. Measured the other way round it is small and finite. Same two beliefs, two answers.

**14. What is Jensen–Shannon divergence, and why was it introduced?** It compares two beliefs by measuring each against their average rather than against each other, which makes it symmetric, bounded, and finite even when one belief calls something impossible. I use it because I needed a drift alarm, and an alarm that returns infinity the first time it sees something new is not an alarm.

**15. What is calibration, and why does it matter for an agent?** An agent is calibrated when the things it calls 0.557 likely happen about 55.7% of the time. It matters because every threshold in this paper takes those probabilities at face value. My expected calibration error is 0.0064—measured on cases drawn from my own likelihood tables, so it says the arithmetic is right, not that the model is.

**16. What is expected cost, and how did you derive your threshold from it?** Expected cost is each outcome's cost weighted by how likely that outcome is. My threshold is the belief at which the two mistakes cost the same: 30 minutes to rotate a key that was already revoked, over $30 + 244.5$ counting the cost of dismissing one that is live. That gives 0.1093, and nobody chose it.

**17. What is value of information? When is more information not worth it?** How much better off I am for having asked, minus what asking cost. It is measured in minutes rather than bits. More information is not worth it when no possible answer would change the action—then its value is zero and its price is not.

**18. Can a question be highly informative and still useless? Give your own example.** Yes, and it is the finding I would lead with. On a well-formed key sitting on a production path, my admin probe carries more information than everything else available put together and is worth 2.9130 minutes against a price of 3. Whatever it returns the agent still rotates—so it loses by 0.087 of a minute and is declined.

**19. What is distribution shift, and how would your agent detect it?** The world stops matching the priors and nothing announces it. My agent detects it with a Jensen–Shannon divergence between the belief it was built with and the belief it has learned from feedback, against a threshold calibrated on held-out windows: 100% detection at a 500-finding window with no false positives.

**20. When should your agent stop searching and act? State the rule.** Stop when no remaining check could change the action, or when the best remaining check costs more than it would save. Both reduce to the same test, applied cheapest-first. In practice the agent buys on 46.8% of findings and stops immediately on the rest.